

# ML 12 Features Risk Weight Matrix

Central Auth Hub — Hybrid RBA 4-Layer

คู่มืออธิบาย 12 features ของ Isolation Forest ที่ใช้ใน Layer 3  
พร้อม risk weight ของแต่ละ feature ใน Layer 1 (Rule) และ Layer 2 (Behavior)

จัดทำจาก code จริงที่ commit ใน main branch:

hub/backend/app/security/rule\_engine.py, behavior\_profiling.py, iforest\_scorer.py, ml-service/app/features.py

# 1. ภาพรวม 4-Layer RBA

ระบบใช้ Hybrid Risk-Based Authentication 4 ชั้น (อ้างอิง Freeman 2016, Wiefling 2022, F-RBA 2024) — ทุก login ผ่าน 4 ชั้นตอนนี้:

| 1 | Rule Engine        | เช็ครูตายตัว: brute force, impossible travel, IP blacklist, new device/country  | score 0.0-1.0, blocked: bool, reasons[]   |
|---|--------------------|---------------------------------------------------------------------------------|-------------------------------------------|
| 2 | Behavior Profiling | เทียบ features ปัจจุบันกับ baseline 30 วันของ user (cold start ถ้า history < 5) | score 0.0-1.0, reasons[]                  |
| 3 | Isolation Forest   | ML unsupervised — ใช้ 12 features ทั้งหมด คำนวณ anomaly score + SHAP top-5      | raw 0.0-1.0 → risk 0.0-0.4, explanation[] |
| 4 | Risk Aggregation   | รวม score จาก 3 ชั้น → final decision                                           | block / challenge / warn / allow          |

Decision thresholds (Layer 4): block ≥ 0.8, challenge ≥ 0.5, warn ≥ 0.3, allow < 0.3

# 2. Risk Weight Matrix — สรุปต่อ feature

ตารางสรุปว่า แต่ละ feature ถูก score ที่ Layer ไหนบ้าง และ weight เท่าไร — อ่านเพื่อรู้ว่า feature ตัวไหนเสี่ยงสูง/ต่ำ:

| 1  | <b>hour_of_day</b><br>Temporal                                  | —                      | indirect (compute typical_hour) | <input type="checkbox"/>        |
|----|-----------------------------------------------------------------|------------------------|---------------------------------|---------------------------------|
| 2  | <b>day_of_week</b><br>Temporal                                  | —                      | indirect (weekend pattern)      | <input type="checkbox"/>        |
| 3  | <b>is_weekend</b><br>Temporal                                   | —                      | +0.10 ถ้า mismatch              | <input type="checkbox"/>        |
| 4  | <b>hours_from_typical_login_time</b><br>Temporal (personalized) | —                      | +0.40 (≥10h) / +0.20 (≥6h)      | <input type="checkbox"/>        |
| 5  | <b>is_thailand</b><br>Geographic                                | +0.10 ถ้า =0           | —                               | <input type="checkbox"/>        |
| 6  | <b>is_new_country</b><br>Geographic                             | +0.30                  | +0.30                           | <input type="checkbox"/>        |
| 7  | <b>country_change_count_30d</b><br>Geographic                   | HARD BLOCK ≥ 8         | —                               | <input type="checkbox"/>        |
| 8  | <b>is_new_device</b><br>Device                                  | +0.30                  | +0.20                           | <input type="checkbox"/>        |
| 9  | <b>is_new_user_agent_family</b><br>Device                       | +0.20                  | —                               | <input type="checkbox"/>        |
| 10 | <b>log_minutes_since_last_login</b><br>Velocity                 | —                      | —                               | <input type="checkbox"/> (only) |
| 11 | <b>login_count_24h</b><br>Velocity                              | HARD BLOCK ≥ 50        | —                               | <input type="checkbox"/>        |
| 12 | <b>failed_logins_24h</b><br>Brute Force                         | +0.20 (≥3), BLOCK ≥ 10 | —                               | <input type="checkbox"/>        |

High-risk features (rank by max total weight):

- ☐ is\_new\_country (max 0.60) — Layer 1 + 2 score สูง
- ☐ is\_new\_device (max 0.50) — Layer 1 + 2 สูง
- ☐ hours\_from\_typical\_login\_time (max 0.40 — Layer 2 ต่ำ)
- ☐ ☐ HARD BLOCK triggers: country\_change\_count\_30d  $\geq 8$ , login\_count\_24h  $\geq 50$ , failed\_logins\_24h  $\geq 10$ , IP blacklist, impossible travel

### 3. รายละเอียดต่อ feature

แต่ละ feature อธิบาย: ทำอะไร, ทำไม่เสี่ยง, weight ที่แต่ละ layer, และ research paper อ้างอิง

#### #1. hour\_of\_day · Temporal · range 0–23

คืออะไร: ชั่วโมงของวันที่ user login (UTC) — 0=เที่ยงคืน, 14=บ่าย 2

เสียงตรงไหน: Attacker มักทำงานนอกเวลาที่เจ้าของบัญชีใช้ปกติ (เช่น ตี 3) — feature นี้คู่กับ behavior profile (feature #4)

|                    |                                 |
|--------------------|---------------------------------|
| Layer 1 (Rule)     | —                               |
| Layer 2 (Behavior) | indirect (compute typical_hour) |
| Layer 3 (IForest)  | <input type="checkbox"/>        |
| Citation           | Wiefling 2022                   |

#### #2. day\_of\_week · Temporal · range 0–6 (Mon–Sun)

คืออะไร: วันในสัปดาห์ที่ login — 0=จันทร์, 6=อาทิตย์

เสียงตรงไหน: ใช้คู่กับ is\_weekend ตรวจสอบ pattern เช่น admin ที่ปกติเช้าจ-ศ แล้วโผล่มาอาทิตย์เช้า

|                    |                            |
|--------------------|----------------------------|
| Layer 1 (Rule)     | —                          |
| Layer 2 (Behavior) | indirect (weekend pattern) |
| Layer 3 (IForest)  | <input type="checkbox"/>   |
| Citation           | Wiefling 2020              |

#### #3. is\_weekend · Temporal · range 0/1

คืออะไร: เป็นวันหยุดเสาร์-อาทิตย์ไหม — 1=ใช่

เสียงตรงไหน: เทียบกับ typical\_weekend ของ user (จาก 30-day profile) — mismatch = สงสัย

|                    |                          |
|--------------------|--------------------------|
| Layer 1 (Rule)     | —                        |
| Layer 2 (Behavior) | +0.10 ถ้า mismatch       |
| Layer 3 (IForest)  | <input type="checkbox"/> |
| Citation           | Wiefling 2022            |

#### #4. hours\_from\_typical\_login\_time · Temporal (personalized) · range 0–12

คืออะไร: ห่างจากเวลาที่ user ปกติ login ก็ชั่วโมง — คำนวณจาก mode ของ hour\_of\_day ใน 30 วัน

เสียงตรงไหน: ห่าง 8-10 ชม. = user ที่ปกติทำงานเช้าโผล่มาตอน 2 ทุ่ม — สัญญาณ takeover แรงมาก. Cold start: ถ้า user มี history < 5 sessions ใช้ค่า neutral (0.0)

|                    |                                            |
|--------------------|--------------------------------------------|
| Layer 1 (Rule)     | —                                          |
| Layer 2 (Behavior) | +0.40 ( $\geq 10h$ ) / +0.20 ( $\geq 6h$ ) |
| Layer 3 (IForest)  | <input type="checkbox"/>                   |
| Citation           | Wiefling 2022 (Sec 5.2)                    |

#### #5. is\_thailand · Geographic · range 0/1

คืออะไร: Login จากไอพีที่ MaxMind GeoIP แมปเป็น TH ไหม — 1=ใช่

เสียงตรงไหน: Hub ของมหา'ลัยคาดว่า user ส่วนใหญ่อยู่ในไทย — login นอกประเทศ = score เพิ่ม +0.10

|                    |               |
|--------------------|---------------|
| Layer 1 (Rule)     | +0.10 ถ้า =0  |
| Layer 2 (Behavior) | —             |
| Layer 3 (IForest)  | □             |
| Citation           | Wiefling 2022 |

## #6. is\_new\_country · Geographic · range 0/1

คืออะไร: ประเทศที่ login ครั้งนี้ เคยอยู่ใน history 30 วันของ user ใหม่ — 0=เคย, 1=ใหม่

เสียงตรงไหน: Feature ที่มี weight สูงสุดรวม: Layer 1 + Layer 2 รวมกัน +0.60 — ประเทศใหม่เป็นสัญญาณ phishing หรือ credential leak ที่ชัดเจน

|                    |                              |
|--------------------|------------------------------|
| Layer 1 (Rule)     | +0.30                        |
| Layer 2 (Behavior) | +0.30                        |
| Layer 3 (IForest)  | □                            |
| Citation           | Freeman 2016 / Wiefling 2022 |

## #7. country\_change\_count\_30d · Geographic · range 0–10+

คืออะไร: นับจำนวนครั้งที่ user เปลี่ยนประเทศใน 30 วันล่าสุด

เสียงตรงไหน: นับ  $\geq 8$  = HARD BLOCK ทันที — pattern ของ botnet หรือ proxy hopping. Normal user 0-2 ครั้งต่อเดือนเท่านั้น

|                    |                               |
|--------------------|-------------------------------|
| Layer 1 (Rule)     | HARD BLOCK $\geq 8$           |
| Layer 2 (Behavior) | —                             |
| Layer 3 (IForest)  | □                             |
| Citation           | Wiefling 2022 (country churn) |

## #8. is\_new\_device · Device · range 0/1

คืออะไร: Device fingerprint (User-Agent + browser family hash) เคยปรากฏใน history ใหม่

เสียงตรงไหน: Weight รวมสูง (+0.50) — Layer 1 +0.30 (rule), Layer 2 +0.20 (behavior). Combine กับ is\_new\_country → 99% เป็น takeover

|                    |                |
|--------------------|----------------|
| Layer 1 (Rule)     | +0.30          |
| Layer 2 (Behavior) | +0.20          |
| Layer 3 (IForest)  | □              |
| Citation           | Laperdrix 2020 |

## #9. is\_new\_user\_agent\_family · Device · range 0/1

คืออะไร: Browser family (Chrome, Safari, Firefox) เคยใช้ใหม่ — ละเอียดยกกว่า is\_new\_device แต่ผันไต่ยากกว่า

เสียงตรงไหน: User-Agent string สามารถ spoof ได้ง่าย แต่การเปลี่ยน browser family บอกได้ว่าการเปลี่ยน OS หรือ device

|                    |       |
|--------------------|-------|
| Layer 1 (Rule)     | +0.20 |
| Layer 2 (Behavior) | —     |

|                   |                             |
|-------------------|-----------------------------|
| Layer 3 (IForest) | <input type="checkbox"/>    |
| Citation          | Laperdrix 2020 / Iqbal 2021 |

## #10. log\_minutes\_since\_last\_login · Velocity · range 0–10+ (log scale)

คืออะไร: Log ของเวลาเป็นนาที่ตั้งแต่ user login ครั้งก่อน —  $\log_{10}(\text{minutes} + 1)$

เสี่ยงตรงไหน: ค่าต่ำมาก (เช่น 0.5 = 2 นาทีก่อน) อาจเป็น session hijack ที่ใช้ token จากเครื่องที่ถูกขโมย ใช้ log scale เพราะ raw minutes กระจายเป็น power law

|                    |                                 |
|--------------------|---------------------------------|
| Layer 1 (Rule)     | —                               |
| Layer 2 (Behavior) | —                               |
| Layer 3 (IForest)  | <input type="checkbox"/> (only) |
| Citation           | Microsoft Entra ID Protection   |

## #11. login\_count\_24h · Velocity · range 0–100+

คืออะไร: จำนวน login สำเร็จของ user ใน 24 ชม. ที่ผ่านมา

เสี่ยงตรงไหน: นับ  $\geq 50$  = HARD BLOCK — pattern ของ credential stuffing หรือ automation. Normal user 1-5 ครั้งต่อวัน

|                    |                          |
|--------------------|--------------------------|
| Layer 1 (Rule)     | HARD BLOCK $\geq 50$     |
| Layer 2 (Behavior) | —                        |
| Layer 3 (IForest)  | <input type="checkbox"/> |
| Citation           | OWASP API4:2023          |

## #12. failed\_logins\_24h · Brute Force · range 0–10+

คืออะไร: จำนวน login ล้มเหลวของ user ใน 24 ชม. (account ถูก challenge แล้วเข้าไม่ได้)

เสี่ยงตรงไหน:  $\geq 3$  = score +0.20 (suspicious).  $\geq 10$  = HARD BLOCK (brute force). NIST SP 800-63B-4 แนะนำให้ rate-limit ที่ตัวเลขนี้

|                    |                                     |
|--------------------|-------------------------------------|
| Layer 1 (Rule)     | +0.20 ( $\geq 3$ ), BLOCK $\geq 10$ |
| Layer 2 (Behavior) | —                                   |
| Layer 3 (IForest)  | <input type="checkbox"/>            |
| Citation           | NIST SP 800-63B-4                   |

## 4. กฎเสริม (ไม่ผูก feature ตรงๆ)

นอกจาก 12 features Layer 1 ยังเช็คกฎ cross-cutting เพิ่มเติม ที่ใช้ context (IP, geo) มากกว่าค่า feature เดียว:

| IP Blacklist      | IP อยู่ใน blacklist table                         | HARD BLOCK  |
|-------------------|---------------------------------------------------|-------------|
| Impossible Travel | user เปลี่ยนประเทศ < 1 ชม. (เช่น TH → US in 0.5h) | HARD BLOCK  |
| Multi-account IP  | > 5 distinct user_id จาก IP เดียวกันใน 1 ชม.      | score +0.25 |

## 5. Layer 3 — SHAP Explainability

Layer 3 (Isolation Forest) ใช้ ทั้ง 12 features รวมกัน เพื่อคำนวณ anomaly score. แต่ score ตัวเดียวไม่บอกว่า feature ไหน contribute เท่าไร — เราใช้ SHAP TreeExplainer (Lundberg & Lee 2017) ให้ค่า per-feature contribution:

Output ที่ ml-service คืน (ตัวอย่าง anomalous login):

```
{
  "anomaly_score": 0.7034,
  "decision": "block",
  "explanation": [
    {"feature": "country_change_count_30d", "shap": 1.58, "direction": "anomaly"},
    {"feature": "failed_logins_24h", "shap": 1.58, "direction": "anomaly"},
    {"feature": "is_new_device", "shap": 1.36, "direction": "anomaly"},
    {"feature": "is_new_user_agent_family", "shap": 1.12, "direction": "anomaly"},
    {"feature": "hours_from_typical_login_time", "shap": 0.85, "direction": "anomaly"}
  ]
}
```

Sign convention (สำคัญ):

- shap > 0 (positive) → feature ผลัก score ไปทาง anomaly (□ แดงใน UI)
- shap < 0 (negative) → feature ผลักไปทาง normal (□ เขียวใน UI)
- Top-5 features เรียงตาม |shap| (absolute value)
- Fail-safe: ถ้า SHAP error → คืน explanation=[] ระบบทำงานต่อได้

ดูใน UI ที่ไหน:

Admin Dashboard → /admin/ml → คลิก session → SessionDetailPanel:

- Risk Score header + 4-Layer breakdown bars
- Reasons (Layer 1 + 2) — bars สีแดง พร้อม weight
- SHAP (Layer 3 · IForest) — bars สี (□ anomaly / □ normal)

## 6. การตีความ Risk Score

Layer 4 รวม score จาก 3 ชั้น แล้วแมปเป็น decision:

| allow     | < 0.3      | ผ่านปกติ — ออก JWT ใช้งานเต็มสิทธิ์                                   |
|-----------|------------|-----------------------------------------------------------------------|
| warn      | 0.3 - 0.49 | ผ่าน + log warning + audit metadata มี iforest_explanation            |
| challenge | 0.5 - 0.79 | ออก JWT แบบ restricted=true (Path B Session Downgrade — รอ implement) |
| block     | ≥ 0.8      | 403 Forbidden + audit + alert admin                                   |

Shadow Mode (ปัจจุบัน): ตั้ง ML\_SHADOW\_MODE=true ใน .env → block/challenge/warn ถูกเปลี่ยนเป็น would\_block/would\_challenge/would\_warn ตามลำดับ (log แต่ไม่บังคับ) — ใช้สำหรับเก็บข้อมูล + ปรับ threshold ก่อนเปิด enforcement จริง

## 7. อ้างอิงงานวิจัย

Liu, Ting, Zhou (2008) — Isolation Forest — ICDM 2008. อัลกอริทึมหลักของ Layer 3.

Freeman et al. (2016) — Who Are You? A Statistical Approach to Measuring User Authenticity. Risk scoring weights สำหรับ new device/country.

Wiefling et al. (2020, 2022) — Pump Up Password Security! / More Than Just Good Passwords? ACM TOPS. Temporal + behavior pattern, RBA effectiveness study.

Lundberg & Lee (2017) — A Unified Approach to Interpreting Model Predictions — NeurIPS. SHAP framework.

Laperdrix et al. (2020) — Browser Fingerprinting Survey. Device fingerprint pitfalls.

F-RBA (2024) — Federated Risk-Based Authentication. Multi-layer architecture pattern.

NIST SP 800-63B-4 (2024 draft) — Digital Identity Guidelines. Failed-login threshold (10), MFA out-of-band.

OWASP API Security Top 10 (2023) — API4 — Unrestricted Resource Consumption (credential stuffing).

Microsoft Entra ID Protection (2024) — Impossible travel + velocity feature definitions.